

Negotiations in Tech : An Analysis of Asymmetric Ransomware Negotiations

Juliette Faivre
University of Cambridge

Abstract

Ransomware attacks have emerged as a significant threat to both private and public organizations, with devastating consequences in terms of data encryption and financial loss. This paper delves into the realm of asymmetric ransomware negotiations, focusing on the power dynamics between cybercriminals and their corporate victims. We assume a targeted ransomware attack scenario, where cybercriminals invest effort in selectively distributing ransomware to specific victims. Drawing on concepts from literature, we analyze the "uneven playing field" created by cybercriminals through illegitimate strategies and unethical means. Additionally, game theory analysis reveals the strategic interactions between both parties, highlighting factors influencing ransom demands and the victim's willingness to pay (WTP). Furthermore, we explore the role of social engineering tactics employed by cybercriminals to coerce and manipulate victims during negotiations. By examining the psychological aspects of communication, we uncover the dynamics of fear and urgency utilized by cybercriminals to drive victim behavior. We also discuss countermeasures that victims can employ to mitigate the effects of social engineering and maximize their interests in negotiation. Ultimately, this paper aims to shed light on the intricacies of asymmetric ransomware negotiations, providing insights for better understanding and responding to this growing cybersecurity threat in the technology domain.

1 Introduction

In 2017, the WannaCry ransomware infected 300,000+ computers worldwide, harming major private and public organisations (e.g. NHS). A ransomware is a form of malicious software (malware) used by cybercriminals to encrypt a victim's data, by breaking into a computer or organisation's network (Palmer (2018)). To recover the data, a decryption key must be obtained, usually traded off by the malicious actor for a ransom (in bitcoins). While ransoms can be targeted or untargeted - specific to a victim or not, the former sort will be discussed in this paper. In fact, we make the assumption that the more investment and effort devoted by malicious actors in discriminately distributing ransoms (targeting), the higher the likelihood will be for both parties to engage in cyber-negotiations (Ryan et al. (2022)). Presuming such a setup for the purposes of this paper, the negotiation dynamics between corporations (victims) and malicious actors (cybercriminals) will be explored. While ransomware negotiations

vary extensively across cases, we will discuss a ‘classic’ setup that excludes third-parties (eg. negotiation firms). By drawing on concepts from the literature (adapted from De Rond (2022), Fisher & Ury (1981)), we will examine the *unequal playing field* (Hack & Wu (2021)), followed by the analysis of strategic interactions in a second part. Ultimately, we will study the persuasion tactics that drive asymmetric ransomware negotiations.

This paper acknowledges Pepijn Hack’s and Zong-Yu Wu’s generous expert advice.

2 An unequal playing field

Before examining the asymmetry of ransomware negotiations, it is critical to understand the underlying motivations of both cybercriminals and their victims. Assuming a classic case, cybercriminals’ actions are driven by ransom-seeking (financial gains) as opposed to the victims, whose interests lie in the safe restoration of their proprietary files - necessary for a return to their day-to-day operations. Nonetheless, the first key aspect to highlight is the predatory nature of the cybercriminal’s motivations, who will deploy unfair and unethical means to satisfy their interests - ultimately creating an asymmetrical negotiation setup. In targeted ransomware attacks, cybercriminals will engage in a thorough selection process of their target based on upfront research and game theory modelling; weighing the costs (effort of hacking into the systems) against the potential monetary gains they can realise.

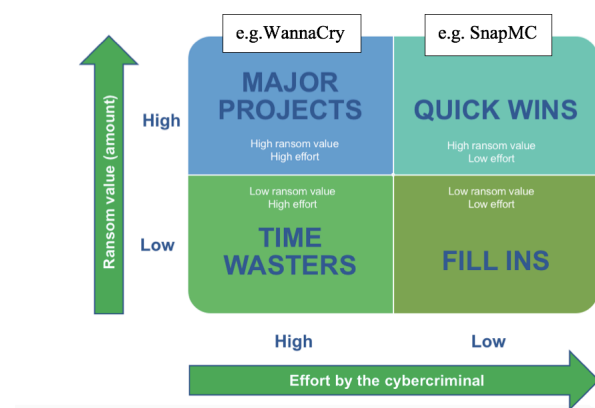


Figure 1: Impact-Effort Matrix, adapted for ransomware attacks based on Cuofano (2022), GroupMap (2022)

Once a cybercriminal performs a ransomware attack on their chosen organisation, encrypting non-proprietary data indicates criminal activity and creates a lock-in situation to the party who legally owns the data (victim). The distorted moral compass of cybercriminals has been widely compared to kidnapping or hostage situations in the literature (Cartwright et al. (2019)), further reinforcing the aspect of illegitimate negotiations. This ‘unequal playing field’ as expressed in a paper by Hack & Wu (2021), is therefore the inception point and cause, of two-fold complications for the victim organisation - 1) the shutdown of its operations which takes a toll on business profits 2) the cybercriminal’s extensive familiarity with the organisation, hence its vulnerability. On the flip side, the victim faces complete information asymmetry (little to no

information about the counterpart's identity, reinforced by the anonymised bitcoin transaction). This accentuates the asymmetrical power distribution, disadvantageous to the victim who cannot discern their counterpart's cues or weaknesses, to improve their vulnerable position. This classic case is categorised as a single-extortion ransomware attack, which encrypts data and paralyzes business activities. Hack & Wu (2021) also expose double-extortion, which they define as the 'threat of publication or selling stolen data'. As they exemplified with SnapMC, the cybercriminal group used to duplicate/steal the data (instead of encrypting it) and threaten the victim to release it in the public domain, if ransoms were not paid within a certain timeframe (Dijkstra (2021)). This greater harm to the organisation's long-term functioning, could reinforce the victim's willingness to pay the ransom by fear of failure (negativity bias). Double-extortion negotiation cases demonstrate an additional 'dirty trick' to *"win substantive gain in an unprincipled contest of will", using threats* (Fisher & Ury (1981), p.129).

3 Game theory analysis

In this second part, the importance of strategic interactions in shaping the negotiations process will be examined. While there may be an asymmetric power relation between both parties as previously explored, cybercriminals have interests to satisfy - which will depend on their victim's moves and receptiveness. Therefore, cybercriminals and victims have strong incentives to engage in negotiations, which disproves the complete powerlessness of victims - as demonstrate Hack & Wu (2021). Studies have shown that ransomware criminals have developed their own advanced pricing strategies; usually starting with extreme ransom demands (Fisher & Ury (1981), p.139), adjusted throughout the negotiation. These depend on various factors such as organisation profits/revenue, willingness to pay (WTP) or sensitiveness, and upfront costs of hacking (Hack & Wu (2021); Haymore (2021)) - among many others that constitute a complex model. It could be argued that the WTP factor is the most 'out-of-hand' to the criminal, as it usually relies on unknown information to the cybercriminal. In fact, it may be uncodified (intangible) and of undisclosed nature. Ryan et al. (2022) have noted the *likelihood of data recovery* or the *"risk that the encrypted data may be duplicated and further monetised"* (as an additional source of financial gains) for the cybercriminal, as key elements guiding the victim's WTP. Nonetheless, the victim faces a moral hazard problem, and can hardly rely on a rapport of trust. Given the unprincipled nature of the negotiation setup (hostage/counterpart's criminal identity), the tarnished credibility can diminish the WTP incentives of the victim. This hesitation is however not desirable from the cybercriminal's perspective, who is better off signalling flexibility and room for ransom negotiation as a way to optimise probabilities for a gain. Yet Ryan et al. (2022) also expose the accumulating costs in the victim's paralysed business activities, making both parties sensitive to time and efficient resolution. Therefore, the negotiation will proceed as follows : the cybercriminal will offer a ransom demand R , awaiting a response from the victim. Depending on their WTP (conditional on the previously mentioned criteria), the victim will either accept, reject or generate a new counteroffer (Ryan et al. (2022)). On their side, cybercriminals may choose to accept, raise the counteroffer (response), or reject the counteroffer if judged too low. This may be seen as antithetic with rational behaviour, since cybercriminals

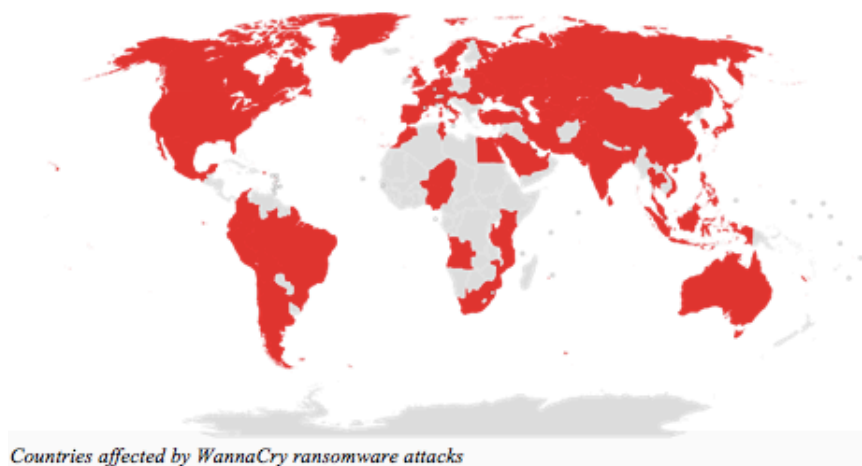
should see a financial benefit even though a lower offer does not fully satisfy their initial request. Given their status quo position being zero or even below zero (due to the upfront investments in the ransomware attack) cybercriminals should not fully withdraw from negotiations. Nonetheless, Ryan et al. (2022) note that cybercriminals may use a “take it or leave it” approach (Fisher & Ury (1981), p.92), to “*maintain their status of threat*” - symbolic of the power asymmetry that they create. This situation could be compared with the ultimatum game, where responders reject minimal sums of money and wish to punish their counterpart because of inequity aversion bias (Vavra et al. (2018)). Therefore, the zone of possible agreement (ZOPA) will depend on both parties’ receptiveness and flexibility to extreme pay-outs (low gains for cybercriminals or high pay-outs from the victims). The BATNA available to the cybercriminal will be restrained (the victims holds the power of the financial gains), unless the newly-acquired data/encryption keys are sellable to third parties (e.g. victim’s competitors). This may present further incentives to engage in ransomware activities considering the attractive alternatives that can equally satisfy their financial interests. Moreover, cybercriminals may choose to perform new attacks – that could equally satisfy their financial interests, depending on the required efforts versus potential gains. Conversely, victims will face WATNA (worst alternative to a negotiated agreement) - term coined by Cristal (2017) in the context of ransomware negotiations. Because of the binary style of the negotiation outcome (decryption/no decryption), victim organisations would typically experience failure in a ‘no agreement’ situation. In a case where the victim would still manage to restore data and return to business activities, damages in technological infrastructure, services, and brand/reputation would still impair daily operations.

4 The role of social engineering

As previously depicted, cybercriminals tend to employ a carrot-and-stick approach when negotiating with their victims : they reward the victims with a decryption key if their interests have been satisfied and can punish (i.e. end negotiations, threaten or publish [a portion] of confidential data) in the opposite case, with hopes to guide their counterpart’s behaviour in their interest. This third part will examine the power of tricked communication, as a key driver in ransomware negotiations. A first important aspect to note is the online nature of the exchange between the cybercriminal and the victim. Being text-based end-to-end, this setup differs with ‘typical’ cases of negotiation that attempt to build a physical connection between both parties. As previously mentioned, the rapport of trust is absent, as is the triad of empathy-credibility(logic)-authenticity of successful negotiations (Frei & Morriss (2020)). This is due to the entirely transactional and one-off nature of the negotiation that does not prioritise a long-term, healthy relationship. Besides, cybercriminals usually attempt to verbally communicate their position of power, by giving instructions and threats, in dictatorial tones. For instance, cybercriminals close down potential alternatives that victims may consider (e.g. asking help from other third-parties to decrypt the data). In fact, in the WannaCry cyberattack, the window on the hacked devices used to outline the following message “[...] *do not waste your time, nobody can recover your files without our decryption service*”.



Locked Window displayed on infected devices



Countries affected by WannaCry ransomware attacks

Figure 2: WannaCry Ransomware, Wikipedia Contributors (2019)

Moreover, using ‘social engineering’ tactics - also known as ‘human hacking’ or manipulation, cybercriminals exploit human errors by tapping on their victim’s psychological weaknesses (Pilette (2021)). Cybercriminals purposefully create an environment of fear and pressure, encouraging the victims to act irrationally via heightened emotions and the feeling of urgency. For example, the window that cybercriminals display on infected devices features dynamic eyecatchers that prompt action and inflict sentiments of endangerment. The WannaCry cyberattack demonstrated emotionally loaded user experience for the victims, comprising two timers (‘payment needs to be raised by’ and ‘files will be [permanently] lost by’) that created a ‘time bomb’ effect on a red coloured background - subconsciously symbolising danger (Krotoski (2014)). However, while cybercriminals aim at creating an environment of fear that coerces the victim to pay, the risk of not receiving the pay-out also needs to be mitigated (given the victim’s unknown WTP). Such uncertainty can be controlled for to a cer-

tain extent, via minimal collaboration with the victim - as mentioned in *Never Split the Difference* (Voss (2016), p.295). Cybercriminals may use incentivising techniques such as a free partial decryption of files to reduce moral hazard (prove that decryption services are efficient) and give the illusion of aligning their own interests with their counterpart's. This shows a certain calculated push-pull art of communication (Bloom (2020)), where in some cases cybercriminals attempt to persuade both by coercing and slightly collaborating, to achieve their goals. Alternately, from the victim's perspective, multiple communication tactics can be employed to counter social engineering. Firstly, recognising the hostage setup will be critical to avoid the escalation of negative emotions, as these may have an unfavourable impact in the negotiations. Fisher & Ury (1981) note the importance of 'focusing on interests instead of positions' p.40. By doing so, victims may respond to dirty tricks by 'inventing options for mutual gains' (Fisher & Ury (1981), p.56), such as requesting a timeframe extension to pay. While this move may be strategic and aimed at different purposes (victim wishes to generate BATNAs/solutions to go around the ransom), the cybercriminal may accept - if this collaboration is deemed to raise the likelihood of receiving financial gains.

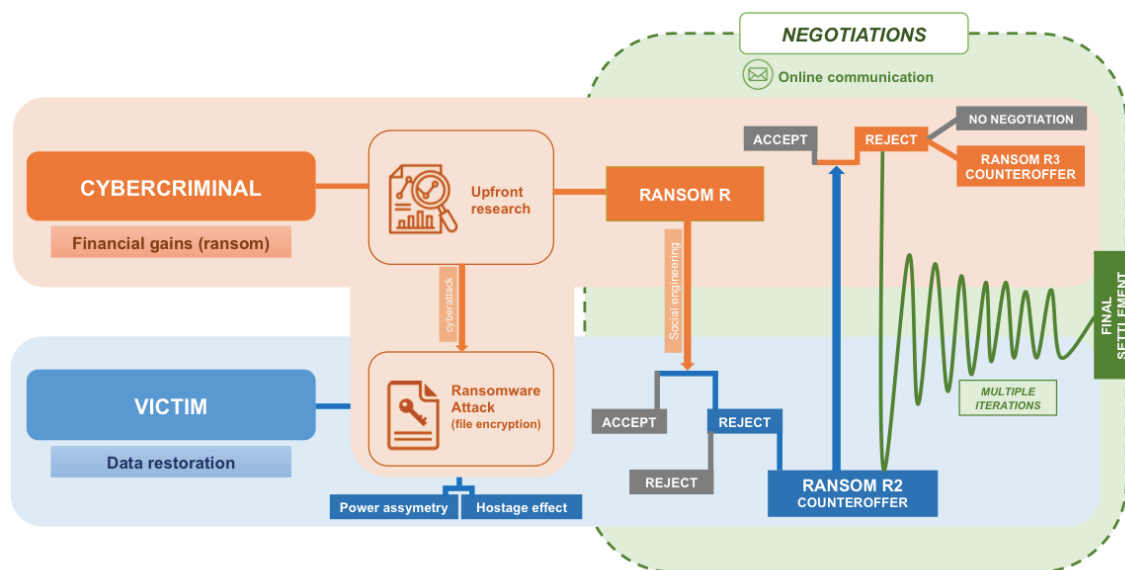


Figure 3: WannaCry Ransomware, Faivre (2023)

5 Conclusion

This paper outlines a classic case of ransomware negotiations between two parties, the cybercriminals (malicious actors) and the victims (corporate organisations) – Appendix 5. Characteristic of a one-sided 'unprincipled' negotiation (Fisher & Ury (1981)), cybercriminals use illegitimate strategies and dirty tactics to control for uncertainty and maximise the WTP incentives of the victim. Conversely, victims need to focus on interests maximisation (minimisation of their own losses) given their hostage position, and avoid emotional responses to psychological pressure tactics, to survive in an increasingly ransomware-threatening environment.

References

- Bloom, E. 2020. Push and pull influence from an it perspective. <https://itmlinstitute.org/push-and-pull-influence-form-an-it-perspective/>. Accessed 13 Mar. 2022.
- Cartwright, E., J. Hernandez Castro & A. Cartwright. 2019. To pay or not: Game theoretic models of ransomware. *Journal of Cybersecurity* 5(1). doi:10.1093/cybsec/tyz009.
- Cristal, M. 2017. How to negotiate when hackers are holding you to ransom. <https://www.wired.co.uk/article/cyber-attacks-hackers-ransoms>. Accessed 11 Dec. 2022.
- Cuofano, G. 2022. Value/effort matrix in a nutshell. <https://fourweekmba.com/value-effort-matrix/>. Accessed 28 Jul. 2022.
- De Rond, Marc. 2022. Negotiations at the university of cambridge (course).
- Dijkstra, M. 2021. Snapmc: Extortion without ransomware. https://www.mynewsdesk.com/nccgroup/blog_posts/snapmc-extortion-without-ransomware-104333. Accessed 11 Dec. 2022.
- Faivre, Juliette. 2023. Simplified schematic ransomware negotiations. Graph created for own paper. Unpublished.
- Fisher, R. & W. Ury. 1981. *Getting to yes: Negotiating agreement without giving in*. Houghton Mifflin Harcourt.
- Frei, F.X. & A. Morriss. 2020. Begin with trust. <https://hbr.org/2020/05/begin-with-trust>.
- GroupMap. 2022. Impact effort matrix template, action priority matrix. <https://www.groupmap.com/portfolio/impact-effort-matrix>. Accessed 12 Dec. 2022.
- Hack, P. & Z.-Y. Wu. 2021. 'we wait, because we know you': Inside the ransomware negotiation economics. https://newsroom.nccgroup.com/blog_posts/we-wait-because-we-know-you-inside-the-ransomware-negotiation-economics-104510?utm_source=rss&utm_medium=rss&utm_campaign=Subscription&utm_content=current_news. Accessed 11 Dec. 2022.
- Haymore, A. 2021. 'we wait, because we know you': Inside the ransomware negotiation economics. <https://research.nccgroup.com/2021/11/12/we-wait-because-we-know-you-inside-the-ransomware-negotiation-economics/>. Accessed 8 Dec. 2022.
- Krotoski, M. 2014. Overcoming the unique challenges presented in 'time bomb' computer intrusion cases. https://www.morganlewis.com/-/media/files/publication/outside-publication/article/krotoski_overcomingchallengesintimebombcases_march2014.pdf. Accessed 12 Dec. 2022.
- Palmer, D. 2018. What is ransomware? everything you need to know about one of the biggest menaces on the web. <https://www.zdnet.com/article/ransomware-an-executive-guide-to-one-of-the-biggest-menaces-on-the-web/>.
- Pilette, C. 2021. What is social engineering? a definition + techniques to watch for. <https://us.norton.com/blog/emerging-threats/what-is-social-engineering#>.
- Ryan, P., J. Fokker, S. Healy & A. Amann. 2022. Dynamics of targeted ransomware

- negotiation. *IEEE Access* 10. 32836–32844. doi:10.1109/access.2022.3160748.
- Vavra, P., L.J. Chang & A.G. Sanfey. 2018. Expectations in the ultimatum game: Distinct effects of mean and variance of expected offers. *Frontiers in Psychology* 9. doi:10.3389/fpsyg.2018.00992.
- Voss, C. 2016. *Never split the difference: Negotiating as if your life depended on it*. Random House Business Books.
- Wikipedia Contributors. 2019. Wannacry ransomware attack. https://en.wikipedia.org/wiki/WannaCry_ransomware_attack. Accessed 12 May 2019.